Phantom Packets — รายงานการวิเคราะห์ระบบเครือข่าย

NETWORK FORENSICS & PACKET CAPTURE ANALYSIS

โจทย์ (Challenge): Phantom Packets	**IP เป้าหมาย:** 172.28.0.10	**หมวดหมู่:** Network Forensics / Crypto
ความยาก: ปานกลาง-สูง	**โปรโตคอล:** DNS / TLS / Git	**สถานะ:** สำเร็จ (2/2 Flags)

บทสรุปผู้บริหาร (EXECUTIVE SUMMARY)

จากการวิเคราะห์ไฟล์บันทึกการรับส่งข้อมูลในเครือข่าย `phantom_packets.pcapng` พบพฤติกรรมบุกรุกระบบ 4 ขั้นตอน ที่มุ่งเป้าไปยังเซิร์ฟเวอร์ภายใน `172.28.0.10` โดยผู้บุกรุกใช้เทคนิค DNS Tunneling ในการขโมย RSA Private Key จากนั้นถอดรหัสข้อมูล TLS ใช้งาน Git Clone เพื่อดึงซอร์สโค้ดโปรเจกต์ `nexline-deploy.git` และสกัดกู้คืนรหัสผ่านลับจากไฟล์คอนฟิกในระบบรวมถึงประวัติการ Commit ใน Git ที่ถูกลบไปแล้ว

ลำดับเหตุการณ์และขั้นตอนการวิเคราะห์ (INVESTIGATION LIFECYCLE)

ขั้นตอนที่ 1: การแอบส่งออกข้อมูลด้วย DNS Tunneling (Private Key Leakage)

ตรวจพบการส่งคำร้องขอ DNS Queries ปริมาณมากไปยัง `status.update-svc-cdn.com` โดยมีรูปแบบ Subdomain เป็นลำดับตัวเลข Hexadecimal เควรีถี่ผิดปกติ

```
0001.308202473082012f...status.update-svc-cdn.com
0002.020100300d06092a...status.update-svc-cdn.com
```

เมื่อนำข้อความ Hexadecimal มาต่อกันตามลำดับ พบว่าเป็นไฟล์ **RSA Private Key (`.pem`)** ของเซิร์ฟเวอร์เป้าหมาย

ขั้นตอนที่ 2: การถอดรหัสการสื่อสาร TLS (Static RSA TLS Decryption)

เนื่องจากเซิร์ฟเวอร์เป้าหมายเปิดใช้งาน Cipher Suites แบบ Static RSA โดยไม่มีกลไก Perfect Forward Secrecy (PFS) การนำ Private Key ที่ได้เข้าโปรแกรม Wireshark จึงสามารถถอดรหัสการสื่อสาร HTTPS/TLS ของพอร์ต 443 ให้กลับมาเป็นข้อมูล Plaintext ได้ทั้งหมด

ขั้นตอนที่ 3: การกู้คืนโครงสร้าง Git Repository (Git Object Extraction)

ภายใน HTTP Traffic ที่ถูกถอดรหัส ตรวจพบคำสั่ง `git clone` ดึงข้อมูลคลังซอร์สโค้ด `nexline-deploy.git` จึงสกัด Raw Git Packfile แล้วใช้ `git unpack-objects` กู้คืนโครงสร้างไฟล์และประวัติ Commit ขึ้นมาวิเคราะห์ในเครื่องท้องถิ่น

ขั้นตอนที่ 4: การค้นหาข้อมูลลับและ Flag (Credential & Flag Recovery)

การวิเคราะห์โครงสร้างไฟล์และประวัติการแก้ไขของ Git Repository พบส่วนประกอบ Flag ทั้งหมดดังนี้:

- **Part 1 (Live Config):** พบในไฟล์ `deploy/staging-vars.conf` บน Branch หลักปัจจุบัน
- **Part 2 (Deleted History):** ตรวจพบ Unlinked Object จากประวัติ commit เก่าที่ถูกลบทิ้งไปแล้ว ในไฟล์ `config/credentials.bak`

สรุปผลการกู้คืน FLAG (FLAG RECOVERY)

Flag Part 1: `TCTT2026_pt1{5b9437e03df7b252}`

Flag Part 2: `TCTT2026_pt2{9562ad4705a54963}`

Combined Flag: `TCTT2026_pt1{5b9437e03df7b252}TCTT2026_pt2{9562ad4705a54963}`

ข้อเสนอแนะเพื่อการป้องกัน (REMEDIATION & MITIGATION)

ประเด็นช่องโหว่	ผลกระทบ	แนวทางแก้ไขและป้องกัน
DNS Exfiltration	ข้อมูลสำคัญรั่วไหลผ่านคำสั่ง DNS Outbound	ตั้งค่าการกรอง DNS ตรวจจับ Query ที่มีค่า Entropy สูง และจำกัดการเชื่อมต่อออกภายนอกด้วย Egress Firewall
Static RSA Cipher Suites	ผู้บุกรุกสามารถถอดรหัส Traffic ย้อนหลังได้	ยกเลิกการใช้ Static RSA บังคับใช้ Cipher Suite ที่รองรับ Perfect Forward Secrecy (เช่น ECDHE)
Secrets ใน Git History	ข้อมูลลับตกค้างในประวัติ commit เก่า	ใช้เครื่องมือลบประวัติ Commit เช่น `git-filter-repo` และทำการยกเลิก/เปลี่ยนค่า Secrets ที่รั่วไหลทันที